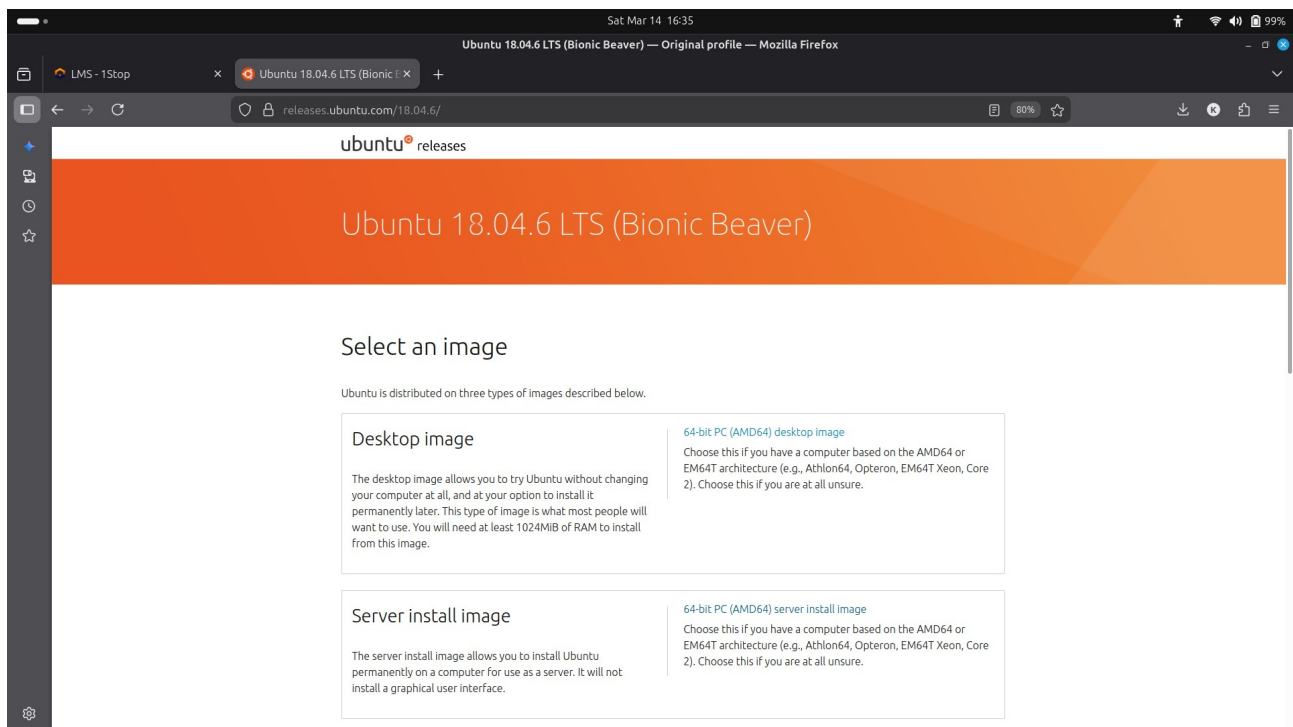


Comprehensive Network and Web Application Security Assessment

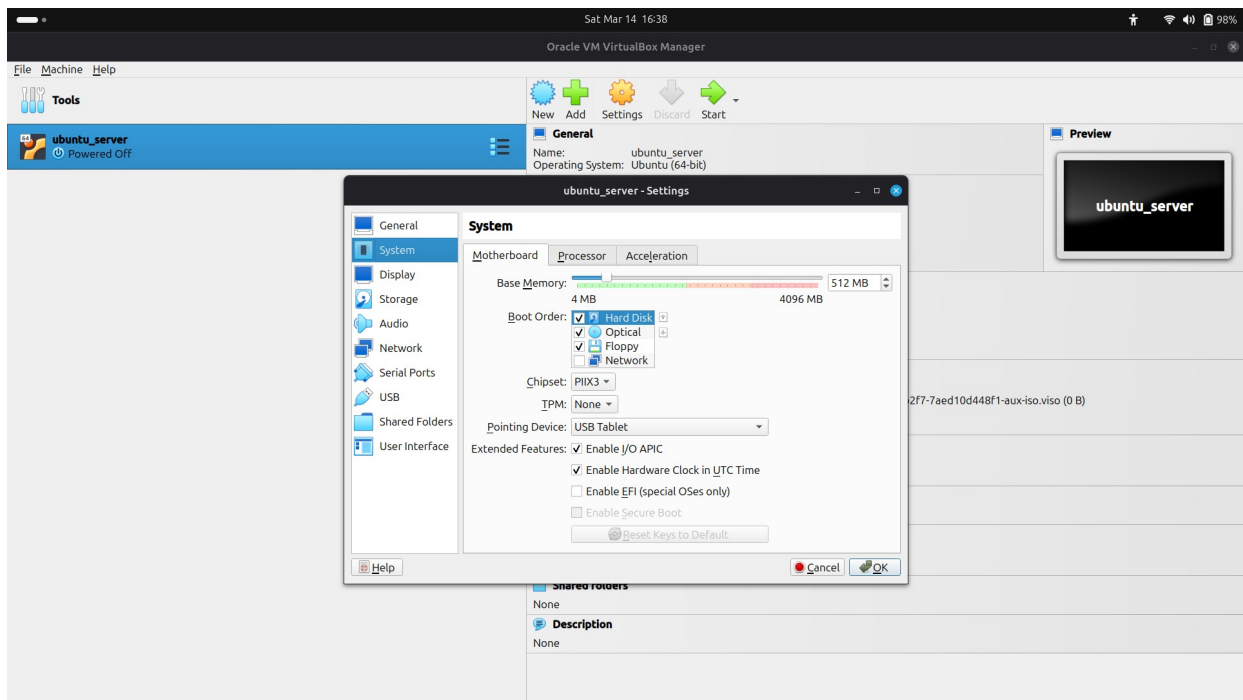
1. Initial Server Setup

- First, we install the ubuntu server image from the official ubuntu website.

Note : As we want to make the server vulnerable we will choose server version 18.04.06.



- After the live .iso image is installed, we will use it to create a Virtual Machine in VirtualBox.



- Then we turn on the VM and follow the installation steps given. **Do not install any patches or packages or security updates.** After the installation we get a login prompt.



```
Ubuntu 18.04.6 LTS ubuntu_server tty1
ubuntu_server login: _
```

- After login we should see a page like this.

```
Ubuntu 18.04.6 LTS ubuntu_server tty1
ubuntu_server login: samsepi01
Password:
Last login: Sat Mar 14 03:34:27 UTC 2026 from 192.168.0.104 on pts/0
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 4.15.0-213-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information disabled due to load higher than 1.0

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

159 updates can be applied immediately.
125 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

samsepi01@ubuntu_server:~$
```

- Then we install telnet,ssh,vsftpd and apache2. Install it through the following command :

```
sudo apt update  
sudo apt-get install telnetd  
sudo systemctl enable inetd.service
```

```
samsepi01@ubuntu_server:~$ sudo systemctl enable inetd  
samsepi01@ubuntu_server:~$ sudo systemctl start inetd  
samsepi01@ubuntu_server:~$
```

```
sudo apt-get install openssh-server  
sudo systemctl start ssh  
sudo systemctl enable ssh
```

```
samsepi01@ubuntu_server:~$ telnet
telnet> ^C
samsepi01@ubuntu_server:~$ sudo apt-get install openssh-server
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  ncurses-term openssh-client openssh-sftp-server ssh-import-id
Suggested packages:
  keychain libpam-ssh monkeysphere ssh-askpass molly-guard rssh
The following NEW packages will be installed:
  ncurses-term openssh-server openssh-sftp-server ssh-import-id
The following packages will be upgraded:
  openssh-client
1 upgraded, 4 newly installed, 0 to remove and 165 not upgraded.
Need to get 1,247 kB of archives.
After this operation, 5,320 kB of additional disk space will be used.
Do you want to continue? [Y/n] Y
```

```
samsepi01@ubuntu_server:~$ sudo systemctl enable ssh --now
Synchronizing state of ssh.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable ssh
samsepi01@ubuntu_server:~$
```

```
sudo apt-get install vsftpd
sudo systemctl start vsftpd
sudo systemctl enable vsftpd
```

```
libwrap0 ssl-cert
Suggested packages:
  openssl-blacklist
The following NEW packages will be installed:
  libwrap0 ssl-cert vsftpd
0 upgraded, 3 newly installed, 0 to remove and 166 not upgraded.
Need to get 179 kB of archives.
After this operation, 505 kB of additional disk space will be used.
Do you want to continue? [Y/n] Y
Get:1 http://in.archive.ubuntu.com/ubuntu bionic/main amd64 libwrap0 amd64 7.6.q-27 [46.3 kB]
Get:2 http://in.archive.ubuntu.com/ubuntu bionic/main amd64 ssl-cert all 1.0.39 [17.0 kB]
Get:3 http://in.archive.ubuntu.com/ubuntu bionic/main amd64 vsftpd amd64 3.0.3-9build1 [115 kB]
Fetched 179 kB in 3s (60.9 kB/s)
Preconfiguring packages ...
Selecting previously unselected package libwrap0:amd64.
(Reading database ... 64625 files and directories currently installed.)
Preparing to unpack .../libwrap0_7.6.q-27_amd64.deb ...
Unpacking libwrap0:amd64 (7.6.q-27) ...
Selecting previously unselected package ssl-cert.
Preparing to unpack .../ssl-cert_1.0.39_all.deb ...
Unpacking ssl-cert (1.0.39) ...
Selecting previously unselected package vsftpd.
Preparing to unpack .../vsftpd_3.0.3-9build1_amd64.deb ...
Unpacking vsftpd (3.0.3-9build1) ...
Setting up ssl-cert (1.0.39) ...
Setting up libwrap0:amd64 (7.6.q-27) ...
Setting up vsftpd (3.0.3-9build1) ...
Created symlink /etc/systemd/system/multi-user.target.wants/vsftpd.service → /lib/systemd/system/vsftpd.service.
invoke-rc.d: policy-rc.d denied execution of start.
Processing triggers for systemd (237-3ubuntu10.52) ...
Processing triggers for man-db (2.8.3-2ubuntu0.1) ...
Processing triggers for ureadahead (0.100.0-21) ...
Processing triggers for libc-bin (2.27-3ubuntu1.5) ...
samsepi01@ubuntu_server:~$ _
```

```
samsepi01@ubuntu_server:~$ ifconfig
enp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:feb1:32e7 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:b1:32:e7 txqueuelen 1000 (Ethernet)
    RX packets 197 bytes 211741 (211.7 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 126 bytes 11353 (11.3 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 102 bytes 9498 (9.4 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 102 bytes 9498 (9.4 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

samsepi01@ubuntu_server:~$ sudo systemctl start vsftpd
samsepi01@ubuntu_server:~$ sudo systemctl enable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable vsftpd
samsepi01@ubuntu_server:~$ _
```

sudo apt-get install apache2

```
samsepi01@ubuntu_server:~$ sudo apt-get install apache2
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  apache2-bin apache2-data apache2-utils libapr1 libaprutil1 libaprutil1-dbd-sqlite3
  libaprutil1-ldap liblua5.2-0
Suggested packages:
  www-browser apache2-doc apache2-suexec-pristine | apache2-suexec-custom
The following NEW packages will be installed:
  apache2 apache2-bin apache2-data apache2-utils libapr1 libaprutil1 libaprutil1-dbd-sqlite3
  libaprutil1-ldap liblua5.2-0
0 upgraded, 9 newly installed, 0 to remove and 165 not upgraded.
Need to get 1,713 kB of archives.
After this operation, 6,936 kB of additional disk space will be used.
Do you want to continue? [Y/n]
```

Then, we configure the `apache2.conf` file with `ServerName <ip>`.

```
GNU nano 2.9.3                apache2.conf                Modified
# * The binary is called apache2. Due to the use of environment variables, in
#   the default configuration, apache2 needs to be started/stopped with
#   /etc/init.d/apache2 or apache2ctl. Calling /usr/bin/apache2 directly will not
#   work with the default configuration.

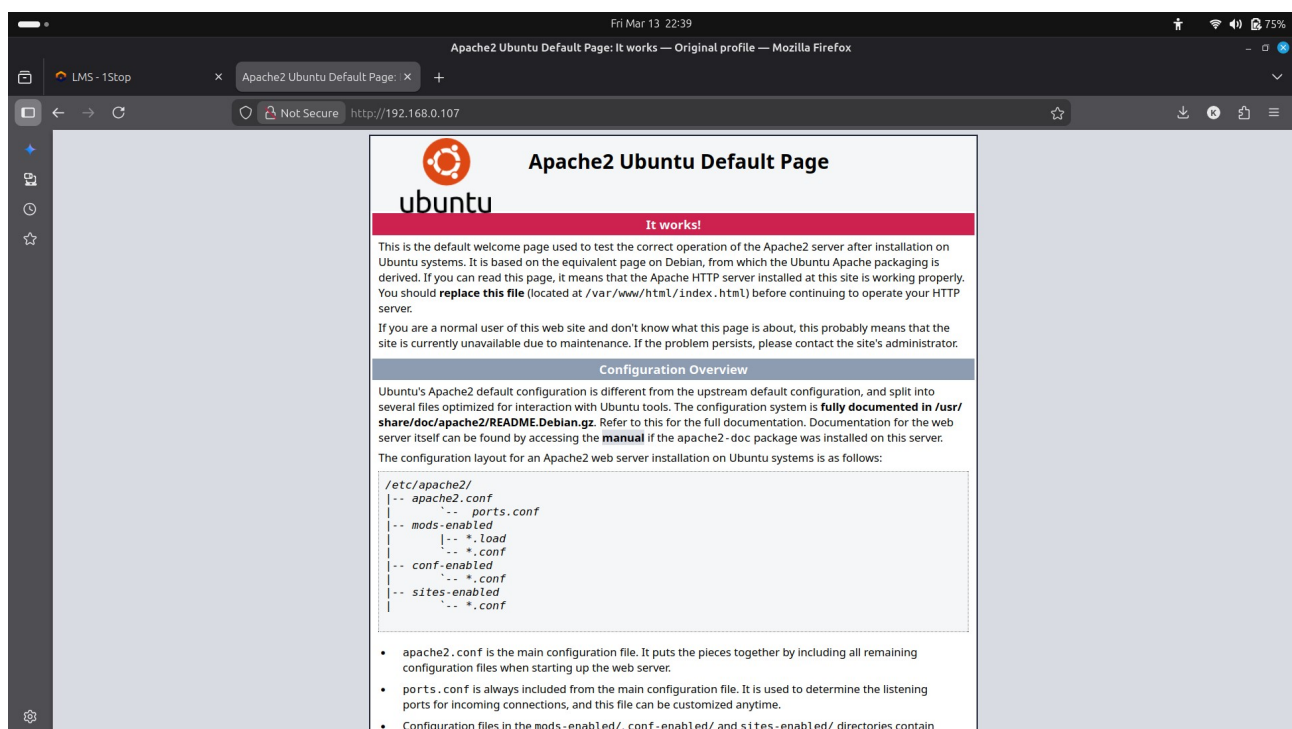
# Global configuration
#
#
# ServerRoot: The top of the directory tree under which the server's
ServerName 192.168.0.107
# configuration, error, and log files are kept.
#
# NOTE! If you intend to place this on an NFS (or otherwise network)
# mounted filesystem then please read the Mutex documentation (available
# at <URL:http://httpd.apache.org/docs/2.4/mod/core.html#mutex>);
# you will save yourself a lot of trouble.
#
# Do NOT add a slash at the end of the directory path.
#ServerRoot "/etc/apache2"
#
# The accept serialization lock file MUST BE STORED ON A LOCAL DISK.
#
#Mutex file:${APACHE_LOCK_DIR} default
#
# The directory where shm and other runtime files will be stored.

^G Get Help      ^O Write Out    ^W Where Is     ^K Cut Text     ^J Justify      ^C Cur Pos      M-U Undo
^X Exit          ^R Read File    ^N Replace      ^U Uncut Text  ^T To Spell     ^_ Go To Line    M-E Redo
```

Now we test if the configuration is error-free or not.

```
samsepi01@ubuntu_server:/etc/apache2$ cd
samsepi01@ubuntu_server:~$ sudo apache2ctl configtest
[sudo] password for samsepi01:
Syntax OK
samsepi01@ubuntu_server:~$
```

Now we restart the server using : `sudo systemctl restart apache2`



- Next, we install mysql-server,php and composer.

`sudo apt-get install mysql-server`

```
samsepi01@ubuntu_server:~$ sudo apt-get install mysql-server
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  libaio1 libcgi-fast-perl libcgi-pm-perl libencode-locale-perl libevent-core-2.1-6 libfcgi-perl
  libhtml-parser-perl libhtml-tagset-perl libhtml-template-perl libhttp-date-perl
  libhttp-message-perl libio-html-perl liblwp-mediatypes-perl libtimedate-perl liburi-perl
  mysql-client-5.7 mysql-client-core-5.7 mysql-common mysql-server-5.7 mysql-server-core-5.7
Suggested packages:
  libdata-dump-perl libipc-sharedcache-perl libwww-perl mailx tinyca
The following NEW packages will be installed:
  libaio1 libcgi-fast-perl libcgi-pm-perl libencode-locale-perl libevent-core-2.1-6 libfcgi-perl
  libhtml-parser-perl libhtml-tagset-perl libhtml-template-perl libhttp-date-perl
  libhttp-message-perl libio-html-perl liblwp-mediatypes-perl libtimedate-perl liburi-perl
  mysql-client-5.7 mysql-client-core-5.7 mysql-common mysql-server mysql-server-5.7
  mysql-server-core-5.7
0 upgraded, 21 newly installed, 0 to remove and 165 not upgraded.
Need to get 20.1 MB of archives.
After this operation, 157 MB of additional disk space will be used.
Do you want to continue? [Y/n] _
```

`sudo systemctl start mysql`

Next we follow on screen instructions.

```

samsepi01@ubuntu_server:~$ mysql
ERROR 2002 (HY000): Can't connect to local MySQL server through socket '/var/run/mysqld/mysqld.sock'
(2)
samsepi01@ubuntu_server:~$ sudo systemctl status mysql
• mysql.service - MySQL Community Server
  Loaded: loaded (/lib/systemd/system/mysql.service; enabled; vendor preset: enabled)
  Active: inactive (dead)
samsepi01@ubuntu_server:~$ sudo systemctl start mysql
samsepi01@ubuntu_server:~$ sudo systemctl status mysql
• mysql.service - MySQL Community Server
  Loaded: loaded (/lib/systemd/system/mysql.service; enabled; vendor preset: enabled)
  Active: active (running) since Fri 2026-03-13 17:16:51 UTC; 2s ago
  Process: 5233 ExecStart=/usr/sbin/mysqld --daemonize --pid-file=/run/mysqld/mysqld.pid (code=exite
  Process: 5211 ExecStartPre=/usr/share/mysql/mysql-systemd-start pre (code=exited, status=0/SUCCESS
  Main PID: 5235 (mysqld)
  Tasks: 27 (limit: 497)
  CGroup: /system.slice/mysql.service
          └─5235 /usr/sbin/mysqld --daemonize --pid-file=/run/mysqld/mysqld.pid

Mar 13 17:16:50 ubuntu_server systemd[1]: Starting MySQL Community Server...
Mar 13 17:16:51 ubuntu_server systemd[1]: Started MySQL Community Server.
samsepi01@ubuntu_server:~$

```

To set up a user : sudo mysql_secure_installation

```

└─5235 /usr/sbin/mysqld --daemonize --pid-file=/run/mysqld/mysqld.pid

Mar 13 17:16:50 ubuntu_server systemd[1]: Starting MySQL Community Server...
Mar 13 17:16:51 ubuntu_server systemd[1]: Started MySQL Community Server.
samsepi01@ubuntu_server:~$ sudo mysql_secure_installation

Securing the MySQL server deployment.

Connecting to MySQL using a blank password.

VALIDATE PASSWORD PLUGIN can be used to test passwords
and improve security. It checks the strength of password
and allows the users to set only those passwords which are
secure enough. Would you like to setup VALIDATE PASSWORD plugin?

Press y|Y for Yes, any other key for No: n
Please set the password for root here.

New password:

Re-enter new password:
By default, a MySQL installation has an anonymous user,
allowing anyone to log into MySQL without having to have
a user account created for them. This is intended only for
testing, and to make the installation go a bit smoother.
You should remove them before moving into a production
environment.

Remove anonymous users? (Press y|Y for Yes, any other key for No) : y
Success.

Normally, root should only be allowed to connect from
'localhost'. This ensures that someone cannot guess at
the root password from the network.

Disallow root login remotely? (Press y|Y for Yes, any other key for No) : _

```

```
a user account created for them. This is intended only for
testing, and to make the installation go a bit smoother.
You should remove them before moving into a production
environment.
```

```
Remove anonymous users? (Press y|Y for Yes, any other key for No) : y
Success.
```

```
Normally, root should only be allowed to connect from
'localhost'. This ensures that someone cannot guess at
the root password from the network.
```

```
Disallow root login remotely? (Press y|Y for Yes, any other key for No) : n
```

```
... skipping.
By default, MySQL comes with a database named 'test' that
anyone can access. This is also intended only for testing,
and should be removed before moving into a production
environment.
```

```
Remove test database and access to it? (Press y|Y for Yes, any other key for No) : y
- Dropping test database...
Success.
```

```
- Removing privileges on test database...
Success.
```

```
Reloading the privilege tables will ensure that all changes
made so far will take effect immediately.
```

```
Reload privilege tables now? (Press y|Y for Yes, any other key for No) : y
Success.
```

```
All done!
samsepi01@ubuntu_server:~$
```

sudo apt-get install php libapache2-mod-php php-mysql

```
samsepi01@ubuntu_server:~$ sudo apt-get install php libapache2-mod-php php-mysql
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  libapache2-mod-php7.2 libsodium23 php-common php7.2 php7.2-cli php7.2-common php7.2-json
  php7.2-mysql php7.2-opcache php7.2-readline
Suggested packages:
  php-pear
The following NEW packages will be installed:
  libapache2-mod-php libapache2-mod-php7.2 libsodium23 php php-common php-mysql php7.2 php7.2-cli
  php7.2-common php7.2-json php7.2-mysql php7.2-opcache php7.2-readline
0 upgraded, 13 newly installed, 0 to remove and 165 not upgraded.
Need to get 4,139 kB of archives.
After this operation, 18.0 MB of additional disk space will be used.
Do you want to continue? [Y/n]
```

Then we edit dir.conf in /etc/apache2/mods-enabled.

Note: Use sudo to make changes.

```
samsepi01@ubuntu_server:~$ sudo apt-get install git -y
Reading package lists... Done
Building dependency tree
Reading state information... Done
git is already the newest version (1:2.17.1-1ubuntu0.18).
git set to manually installed.
0 upgraded, 0 newly installed, 0 to remove and 165 not upgraded.
samsepi01@ubuntu_server:~$ cd /etc/apache2
samsepi01@ubuntu_server:/etc/apache2$ ls
apache2.conf      conf-enabled      magic             mods-enabled      sites-available
conf-available    envvars           mods-available    ports.conf        sites-enabled
samsepi01@ubuntu_server:/etc/apache2$ cd mods-enabled
samsepi01@ubuntu_server:/etc/apache2/mods-enabled$ ls
access_compat.load  authz_core.load   deflate.load      mime.load         php7.2.load       status.load
alias.conf          authz_host.load   dir.conf          mpm_prefork.conf reqtimeout.conf
alias.load          authz_user.load   dir.load          mpm_prefork.load reqtimeout.load
auth_basic.load     autoindex.conf    env.load          negotiation.conf  setenvif.conf
authn_core.load     autoindex.load    filter.load       negotiation.load  setenvif.load
authn_file.load     deflate.conf       mime.conf         php7.2.conf       status.conf
samsepi01@ubuntu_server:/etc/apache2/mods-enabled$ sudo nano dir.conf
```

DirectoryIndex index.php ...#rest of the index.format

```
GNU nano 2.9.8                                dir.conf                                Modified
<IfModule mod_dir.c>
    DirectoryIndex index.php index.html index.cgi index.pl index.xhtml index.htm
</IfModule>

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet

^G Get Help      ^O Write Out     ^W Where Is      ^K Cut Text      ^J Justify       ^C Cur Pos       M-U Undo
^X Exit          ^R Read File     ^_ Replace       ^U Uncut Text    ^T To Spell      ^_ Go To Line     M-E Redo
```

Then we restart the apache server.

`sudo systemctl restart apache2`

```
samsepi01@ubuntu_server:/etc/apache2/mods-enabled$ sudo systemctl restart apache2
samsepi01@ubuntu_server:/etc/apache2/mods-enabled$ sudo systemctl status apache2

Command 'sudo' not found, did you mean:

  command 'sumo' from deb sumo
  command 'sudo' from deb sudo
  command 'sudo' from deb sudo-ldap

Try: sudo apt install <deb name>

samsepi01@ubuntu_server:/etc/apache2/mods-enabled$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
   Drop-In: /lib/systemd/system/apache2.service.d
            └─apache2-systemd.conf
   Active: active (running) since Fri 2026-03-13 17:25:38 UTC; 19s ago
     Process: 12447 ExecStop=/usr/sbin/apachectl stop (code=exited, status=0/SUCCESS)
     Process: 12463 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
    Main PID: 12470 (apache2)
      Tasks: 6 (limit: 497)
   CGroup: /system.slice/apache2.service
           └─12470 /usr/sbin/apache2 -k start
             └─12473 /usr/sbin/apache2 -k start
               └─12474 /usr/sbin/apache2 -k start
                 └─12475 /usr/sbin/apache2 -k start
                   └─12476 /usr/sbin/apache2 -k start
                     └─12477 /usr/sbin/apache2 -k start

Mar 13 17:25:38 ubuntu_server systemd[1]: Starting The Apache HTTP Server...
Mar 13 17:25:38 ubuntu_server systemd[1]: Started The Apache HTTP Server.
samsepi01@ubuntu_server:/etc/apache2/mods-enabled$
```

Fri Mar 13 23:03

phpinfo() — Original profile — Mozilla Firefox

phpinfo()

Not Secure http://192.168.0.107/info.php

PHP Version 7.2.24-0ubuntu0.18.04.17

System	Linux ubuntu_server 4.15.0-213-generic #224-Ubuntu SMP Mon Jun 19 13:30:12 UTC 2023 x86_64
Build Date	Feb 23 2023 13:29:25
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.2/apache2
Loaded Configuration File	/etc/php/7.2/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/7.2/apache2/conf.d
Additional .ini files parsed	/etc/php/7.2/apache2/conf.d/10-mysqlnd.ini, /etc/php/7.2/apache2/conf.d/10-opcache.ini, /etc/php/7.2/apache2/conf.d/10-pdo.ini, /etc/php/7.2/apache2/conf.d/20-calendar.ini, /etc/php/7.2/apache2/conf.d/20-ctype.ini, /etc/php/7.2/apache2/conf.d/20-exif.ini, /etc/php/7.2/apache2/conf.d/20-fileinfo.ini, /etc/php/7.2/apache2/conf.d/20-ftp.ini, /etc/php/7.2/apache2/conf.d/20-gettext.ini, /etc/php/7.2/apache2/conf.d/20-iconv.ini, /etc/php/7.2/apache2/conf.d/20-json.ini, /etc/php/7.2/apache2/conf.d/20-mysqli.ini, /etc/php/7.2/apache2/conf.d/20-pdo_mysql.ini, /etc/php/7.2/apache2/conf.d/20-phar.ini, /etc/php/7.2/apache2/conf.d/20-posix.ini, /etc/php/7.2/apache2/conf.d/20-readline.ini, /etc/php/7.2/apache2/conf.d/20-shmop.ini, /etc/php/7.2/apache2/conf.d/20-sockets.ini, /etc/php/7.2/apache2/conf.d/20-sysmsg.ini, /etc/php/7.2/apache2/conf.d/20-syssem.ini, /etc/php/7.2/apache2/conf.d/20-sysshm.ini, /etc/php/7.2/apache2/conf.d/20-tokenizer.ini
PHP API	20170718
PHP Extension	20170718
Zend Extension	320170718
Zend Extension Build	API320170718,NTS
PHP Extension Build	API20170718,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	disabled
IPv6 Support	enabled
DTrace Support	available, disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar

Next, we install php-all-dev.

```
samsepi01@ubuntu_server:~$ sudo apt-cache show php-all-dev
Package: php-all-dev
Architecture: all
Version: 1:60ubuntu1
Priority: optional
Section: php
Source: php-defaults (60ubuntu1)
Origin: Ubuntu
Maintainer: Ubuntu Developers <ubuntu-devel-discuss@lists.ubuntu.com>
Original-Maintainer: Debian PHP Maintainers <pkg-php-maint@lists.alioth.debian.org>
Bugs: https://bugs.launchpad.net/ubuntu/+filebug
Installed-Size: 12
Depends: php7.2-dev, php7.2-json
Filename: pool/main/p/php-defaults/php-all-dev_60ubuntu1_all.deb
Size: 3004
MD5sum: 03c8b003a768f7d38f2b851285998671
SHA1: 8f9205b25f79600ae1c33b20fb6254f899a1f099
SHA256: 10ec8d63e04d9f4de0517648a7920587e1f86be6e44147e805d9209006f93fb0
Description: package depending on all supported PHP development packages
Description-md5: 282387dcc5e856a26822d74f9e5680e3
Supported: 5y

samsepi01@ubuntu_server:~$ _
```

```
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  autoconf automake autopoint autotools-dev binutils binutils-common binutils-x86-64-linux-gnu
  build-essential cpp cpp-7 debhelper dh-autoreconf dh-strip-nondeterminism dpkg-dev fakeroot g++
  g++-7 gcc gcc-7 gcc-7-base gettext intltool-debian libalgorithm-diff-perl
  libalgorithm-diff-xs-perl libalgorithm-merge-perl libarchive-cpio-perl libarchive-zip-perl
  libasan4 libatomic1 libbinutils libc-dev-bin libc6 libc6-dev libcc1-0 libcilkrts5 libcroco3
  libdpkg-perl libfakeroot libfile-fcntllock-perl libfile-stripnondeterminism-perl libgcc-7-dev
  libgomp1 libisl19 libitm1 liblsan0 libltdl-dev libltdl7 libmail-sendmail-perl libmpc3 libmpx2
  libpcre16-3 libpcre3 libpcre3-dev libpcre32-3 libpcrecpp0v5 libquadmath0 libssl-dev libssl1.1
  libstdc++-7-dev libsys-hostname-long-perl libtool libtsan0 libubsan0 linux-libc-dev m4 make
  manpages-dev php-pear php-xml php7.2-dev php7.2-xml pkg-php-tools po-debconf shtool
Suggested packages:
  autoconf-archive gnu-standards autoconf-doc binutils-doc cpp-doc gcc-7-locales dh-make dwz
  debian-keyring g++-multilib g++-7-multilib gcc-7-doc libstdc++6-7-dbg gcc-multilib flex bison
  gdb gcc-doc gcc-7-multilib libgcc1-dbg libgomp1-dbg libitm1-dbg libatomic1-dbg libasan4-dbg
  liblsan0-dbg libtsan0-dbg libubsan0-dbg libcilkrts5-dbg libmpx2-dbg libquadmath0-dbg gettext-doc
  libasprintf-dev libgettextpo-dev glibc-doc bzip libtool-doc libssl-doc libstdc++-7-doc gfortran
  | fortran95-compiler gcj-jdk m4-doc make-doc dh-php libmail-box-perl
The following NEW packages will be installed:
  autoconf automake autopoint autotools-dev binutils binutils-common binutils-x86-64-linux-gnu
  build-essential cpp cpp-7 debhelper dh-autoreconf dh-strip-nondeterminism dpkg-dev fakeroot g++
  g++-7 gcc gcc-7 gcc-7-base gettext intltool-debian libalgorithm-diff-perl
  libalgorithm-diff-xs-perl libalgorithm-merge-perl libarchive-cpio-perl libarchive-zip-perl
  libasan4 libatomic1 libbinutils libc-dev-bin libc6-dev libcc1-0 libcilkrts5 libcroco3
  libdpkg-perl libfakeroot libfile-fcntllock-perl libfile-stripnondeterminism-perl libgcc-7-dev
  libgomp1 libisl19 libitm1 liblsan0 libltdl-dev libltdl7 libmail-sendmail-perl libmpc3 libmpx2
  libpcre16-3 libpcre3-dev libpcre32-3 libpcrecpp0v5 libquadmath0 libssl-dev libstdc++-7-dev
  libsys-hostname-long-perl libtool libtsan0 libubsan0 linux-libc-dev m4 make manpages-dev
  php-all-dev php-pear php-xml php7.2-dev php7.2-xml pkg-php-tools po-debconf shtool
The following packages will be upgraded:
  libc6 libpcre3 libssl1.1
3 upgraded, 72 newly installed, 0 to remove and 162 not upgraded.
Need to get 53.9 MB/55.4 MB of archives.
After this operation, 202 MB of additional disk space will be used.
Do you want to continue? [Y/n] Y_
```

Next we move to info.php.

Use : `sudo nano /var/www/html/info.php`

Code :

```
<?php
    phpinfo();
?>
```

Save and exit.

Then,we install composer.

```
samsepi01@ubuntu_server:~$ sudo apt-get install composer
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  jsonlint php-cli-prompt php-composer-ca-bundle php-composer-semver php-composer-spdx-licenses
  php-json-schema php-psr-log php-symfony-console php-symfony-debug php-symfony-filesystem
  php-symfony-finder php-symfony-polyfill-mbstring php-symfony-process
Suggested packages:
  fossil mercurial subversion php-zip php-symfony-event-dispatcher php-symfony-lock php-mbstring
The following NEW packages will be installed:
  composer jsonlint php-cli-prompt php-composer-ca-bundle php-composer-semver
  php-composer-spdx-licenses php-json-schema php-psr-log php-symfony-console php-symfony-debug
  php-symfony-filesystem php-symfony-finder php-symfony-polyfill-mbstring php-symfony-process
0 upgraded, 14 newly installed, 0 to remove and 162 not upgraded.
Need to get 586 kB of archives.
After this operation, 3,482 kB of additional disk space will be used.
Do you want to continue? [Y/n] _
```

Composer will be used to create a Laravel project involving a vulnerable php login page.

```

-v|vv|vvv, --verbose          Increase the verbosity of messages: 1 for normal output, 2 for more
verbose output and 3 for debug

Available commands:
  about                Shows the short information about Composer.
  archive              Creates an archive of this composer package.
  browse              [home] Opens the package's repository URL or homepage in your browser.
  check-platform-reqs Check that platform requirements are satisfied.
  clear-cache          [clearcache] Clears composer's internal package cache.
  config              Sets config options.
  create-project       Creates new project from a package into given directory.
  depends             [why] Shows which packages cause the given package to be installed.
  diagnose            Diagnoses the system to identify common errors.
  dump-autoload        [dumpautoload] Dumps the autoloader.
  exec                Executes a vendored binary/script.
  global              Allows running commands in the global composer dir ($COMPOSER_HOME).
  help                Displays help for a command
  init                Creates a basic composer.json file in current directory.
  install             Installs the project dependencies from the composer.lock file if present, or
falls back on the composer.json.
  licenses            Shows information about licenses of dependencies.
  list                Lists commands
  outdated            Shows a list of installed packages that have updates available, including the
ir latest version.
  prohibits           [why-not] Shows which packages prevent the given package from being installed
.
  remove             Removes a package from the require or require-dev.
  require             Adds required packages to your composer.json and installs them.
  run-script          Runs the scripts defined in composer.json.
  search              Searches for packages.
  show               [info] Shows information about packages.
  status             Shows a list of locally modified packages.
  suggests            Shows package suggestions.
  update             [upgrade] Upgrades your dependencies to the latest version according to compo
ser.json, and updates the composer.lock file.
  validate            Validates a composer.json and composer.lock.
samsepi01@ubuntu_server:~$

```

Then we clone the laravel-vulnerable-app from github. To enable permissions, run these commands :

1. `sudo chmod 2777 /var/www && find /var/www -type d -exec sudo chmod 2777 {} \;`
2. `find /var/www -type f -exec sudo chmod 0777 {} \;`

`find /var/www -type d`: This looks specifically for directories (folders) within /var/www.

- **777**: This gives the Owner, the Group, and Everyone else full permissions (Read, Write, and Execute).
- **2** is set on a directory, any new files created inside it will automatically inherit the **Group ID** of the parent directory, rather than the Group ID of the user who created the file.

find /var/www -type f: This looks specifically for files.

- 0777: This gives everyone (Owner, Group, World) permission to Read, Write, and Execute the files.

```
samsepi01@ubuntu_server:/var/www/html$ cd ..
samsepi01@ubuntu_server:/var/www$ sudo chmod 2777 /var/www && find /var/www -type d -exec sudo chmod
2777 {} \;
[sudo] password for samsepi01:
samsepi01@ubuntu_server:/var/www$ ls -la
total 12
drwxrwsrwx 3 root root 4096 Mar 13 16:21 .
drwxr-xr-x 14 root root 4096 Mar 13 16:21 ..
drwxrwsrwx 2 root root 4096 Mar 13 17:32 html
samsepi01@ubuntu_server:/var/www$ find /var/www -type f -exec sudo chmod 0777 {} \;
samsepi01@ubuntu_server:/var/www$ ls -la
total 12
drwxrwsrwx 3 root root 4096 Mar 13 16:21 .
drwxr-xr-x 14 root root 4096 Mar 13 16:21 ..
drwxrwsrwx 2 root root 4096 Mar 13 17:32 html
samsepi01@ubuntu_server:/var/www$ cd html
samsepi01@ubuntu_server:/var/www/html$ ls
index.html  info.php
samsepi01@ubuntu_server:/var/www/html$ ls -la
total 24
drwxrwsrwx 2 root root 4096 Mar 13 17:32 .
drwxrwsrwx 3 root root 4096 Mar 13 16:21 ..
-rwxrwxrwx 1 root root 10918 Mar 13 16:21 index.html
-rwxrwxrwx 1 root root 20 Mar 13 17:32 info.php
samsepi01@ubuntu_server:/var/www/html$ git clone https://github.com/dennisehcs/vulnerable-laravel-ap
p.git
Cloning into 'vulnerable-laravel-app'...
remote: Enumerating objects: 255, done.
remote: Counting objects: 100% (38/38), done.
remote: Compressing objects: 100% (12/12), done.
remote: Total 255 (delta 27), reused 26 (delta 26), pack-reused 217 (from 1)
Receiving objects: 100% (255/255), 588.64 KiB | 2.59 MiB/s, done.
Resolving deltas: 100% (77/77), done.
samsepi01@ubuntu_server:/var/www/html$
```

Then cd into the vulnerable-laravel-app. And try to run composer install.

The errors must be recorded in a output.log from where we can see and accordingly install the missing dependencies.

```

samsepi01@ubuntu_server:/var/www$ ls -la
total 12
drwxrwsrwx 3 root root 4096 Mar 13 16:21
drwxr-xr-x 14 root root 4096 Mar 13 16:21 ..
drwxrwsrwx 2 root root 4096 Mar 13 17:32 html
samsepi01@ubuntu_server:/var/www$ cd html
samsepi01@ubuntu_server:/var/www/html$ ls
index.html info.php
samsepi01@ubuntu_server:/var/www/html$ ls -la
total 24
drwxrwsrwx 2 root root 4096 Mar 13 17:32
drwxrwsrwx 3 root root 4096 Mar 13 16:21
-rwxrwxrwx 1 root root 10918 Mar 13 16:21 index.html
-rwxrwxrwx 1 root root 20 Mar 13 17:32 info.php
samsepi01@ubuntu_server:/var/www/html$ git clone https://github.com/dennisehcs/vulnerable-laravel-app
p.git
Cloning into 'vulnerable-laravel-app'...
remote: Enumerating objects: 255, done.
remote: Counting objects: 100% (38/38), done.
remote: Compressing objects: 100% (12/12), done.
remote: Total 255 (delta 27), reused 26 (delta 26), pack-reused 217 (from 1)
Receiving objects: 100% (255/255), 588.64 KiB | 2.59 MiB/s, done.
Resolving deltas: 100% (77/77), done.
samsepi01@ubuntu_server:/var/www/html$ ls -la
total 28
drwxrwsrwx 3 root root 4096 Mar 13 18:06
drwxrwsrwx 3 root root 4096 Mar 13 16:21
-rwxrwxrwx 1 root root 10918 Mar 13 16:21 index.html
-rwxrwxrwx 1 root root 20 Mar 13 17:32 info.php
drwxrwsr-x 13 samsepi01 root 4096 Mar 13 18:06 vulnerable-laravel-app
samsepi01@ubuntu_server:/var/www/html$ cd vulnerable-laravel-app
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ ls
app composer.lock docker-compose.yml public server.php test.txt
artisan config Dockerfile README.md storage webpack.mix.js
bootstrap database package.json resources tailwind.config.js yarn.lock
composer.json docker phpunit.xml routes tests
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$

```

```

GNU nano 2.9.3 output.log
Loading composer repositories with package information
Installing dependencies (including require-dev) from lock file
Your requirements could not be resolved to an installable set of packages.

Problem 1
- Installation request for erusev/parsedown 1.7.3 -> satisfiable by erusev/parsedown[1.7.3].
- erusev/parsedown 1.7.3 requires ext-mbstring * -> the requested PHP extension mbstring is mis$
Problem 2
- Installation request for laravel/framework v5.8.31 -> satisfiable by laravel/framework[v5.8.3$
- laravel/framework v5.8.31 requires ext-mbstring * -> the requested PHP extension mbstring is $
Problem 3
- Installation request for phpunit/phpunit 7.5.14 -> satisfiable by phpunit/phpunit[7.5.14].
- phpunit/phpunit 7.5.14 requires ext-mbstring * -> the requested PHP extension mbstring is mis$
Problem 4
- laravel/framework v5.8.31 requires ext-mbstring * -> the requested PHP extension mbstring is $
- beyondcode/laravel-dump-server 1.2.2 requires illuminate/console 5.6.*|5.7.*|5.8.* -> satisfi$
- Installation request for beyondcode/laravel-dump-server 1.2.2 -> satisfiable by beyondcode/la$

To enable extensions, verify that they are enabled in your .ini files:
- /etc/php/7.2/cli/php.ini
- /etc/php/7.2/cli/conf.d/10-mysqlnd.ini
- /etc/php/7.2/cli/conf.d/10-opcache.ini
- /etc/php/7.2/cli/conf.d/10-pdo.ini
- /etc/php/7.2/cli/conf.d/15-xml.ini
- /etc/php/7.2/cli/conf.d/20-calendar.ini
- /etc/php/7.2/cli/conf.d/20-ctype.ini
- /etc/php/7.2/cli/conf.d/20-dom.ini
- /etc/php/7.2/cli/conf.d/20-exif.ini
- /etc/php/7.2/cli/conf.d/20-fileinfo.ini
- /etc/php/7.2/cli/conf.d/20-ftp.ini
- /etc/php/7.2/cli/conf.d/20-gettext.ini
- /etc/php/7.2/cli/conf.d/20-iconv.ini
[ Read 50 lines ]
^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos M-U Undo
^X Exit ^R Read File ^\ Replace ^U Uncut Text ^T To Spell ^_ Go To Line M-E Redo

```

According to the log file, it is php-mbstring and php-zip.

```
The following additional packages will be installed:
  php7.2-mbstring
The following NEW packages will be installed:
  php-mbstring php7.2-mbstring
0 upgraded, 2 newly installed, 0 to remove and 162 not upgraded.
Need to get 486 kB of archives.
After this operation, 1,723 kB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://in.archive.ubuntu.com/ubuntu bionic-updates/universe amd64 php7.2-mbstring amd64 7.2.24-0ubuntu0.18.04.17 [484 kB]
Get:2 http://in.archive.ubuntu.com/ubuntu bionic/universe amd64 php-mbstring all 1:7.2+60ubuntu1 [2,008 B]
Fetched 486 kB in 4s (137 kB/s)
Selecting previously unselected package php7.2-mbstring.
(Reading database ... 77280 files and directories currently installed.)
Preparing to unpack .../php7.2-mbstring_7.2.24-0ubuntu0.18.04.17_amd64.deb ...
Unpacking php7.2-mbstring (7.2.24-0ubuntu0.18.04.17) ...
Selecting previously unselected package php-mbstring.
Preparing to unpack .../php-mbstring_1%3a7.2+60ubuntu1_all.deb ...
Unpacking php-mbstring (1:7.2+60ubuntu1) ...
Setting up php7.2-mbstring (7.2.24-0ubuntu0.18.04.17) ...

Creating config file /etc/php/7.2/mods-available/mbstring.ini with new version
Setting up php-mbstring (1:7.2+60ubuntu1) ...
Processing triggers for libapache2-mod-php7.2 (7.2.24-0ubuntu0.18.04.17) ...
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ sudo apt-get install php-zip
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  libzip4 php7.2-zip
The following NEW packages will be installed:
  libzip4 php-zip php7.2-zip
0 upgraded, 3 newly installed, 0 to remove and 162 not upgraded.
Need to get 60.1 kB of archives.
After this operation, 204 kB of additional disk space will be used.
Do you want to continue? [Y/n] _
```

```
The following NEW packages will be installed:
  libzip4 php-zip php7.2-zip
0 upgraded, 3 newly installed, 0 to remove and 162 not upgraded.
Need to get 60.1 kB of archives.
After this operation, 204 kB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://in.archive.ubuntu.com/ubuntu bionic/universe amd64 libzip4 amd64 1.1.2-1.1 [37.8 kB]
Get:2 http://in.archive.ubuntu.com/ubuntu bionic-updates/universe amd64 php7.2-zip amd64 7.2.24-0ubuntu0.18.04.17 [20.3 kB]
Get:3 http://in.archive.ubuntu.com/ubuntu bionic/universe amd64 php-zip all 1:7.2+60ubuntu1 [1,996 B]
Fetched 60.1 kB in 1s (53.0 kB/s)
Selecting previously unselected package libzip4:amd64.
(Reading database ... 77292 files and directories currently installed.)
Preparing to unpack .../libzip4_1.1.2-1.1_amd64.deb ...
Unpacking libzip4:amd64 (1.1.2-1.1) ...
Selecting previously unselected package php7.2-zip.
Preparing to unpack .../php7.2-zip_7.2.24-0ubuntu0.18.04.17_amd64.deb ...
Unpacking php7.2-zip (7.2.24-0ubuntu0.18.04.17) ...
Selecting previously unselected package php-zip.
Preparing to unpack .../php-zip_1%3a7.2+60ubuntu1_all.deb ...
Unpacking php-zip (1:7.2+60ubuntu1) ...
Setting up libzip4:amd64 (1.1.2-1.1) ...
Setting up php7.2-zip (7.2.24-0ubuntu0.18.04.17) ...

Creating config file /etc/php/7.2/mods-available/zip.ini with new version
Setting up php-zip (1:7.2+60ubuntu1) ...
Processing triggers for libapache2-mod-php7.2 (7.2.24-0ubuntu0.18.04.17) ...
Processing triggers for libc-bin (2.27-3ubuntu1.5) ...
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ composer install
Loading composer repositories with package information
Installing dependencies (including require-dev) from lock file
Package operations: 85 installs, 0 updates, 0 removals
  - Installing doctrine/inflector (v1.3.0): Downloading (100%)
  - Installing doctrine/lexer (1.1.0): Downloading (100%)
  - Installing dragonmantank/cron-expression (v2.3.0): Downloading (100%)
  - Installing erusev/parsedown (1.7.3): Downloading (connecting...) _
```

Then create a key using `php artisan key:generate`

```
drwxrwsr-x 14 samsepi01 root 4096 Mar 13 18:21 .
drwxrwsrwx 3 root root 4096 Mar 13 18:06 .
drwxrwsr-x 6 samsepi01 root 4096 Mar 13 18:06 app
-rw-rw-r-- 1 samsepi01 root 1686 Mar 13 18:06 artisan
drwxrwsr-x 3 samsepi01 root 4096 Mar 13 18:06 bootstrap
-rw-rw-r-- 1 samsepi01 root 1715 Mar 13 18:06 composer.json
-rw-rw-r-- 1 samsepi01 root 176852 Mar 13 18:06 composer.lock
drwxrwsr-x 2 samsepi01 root 4096 Mar 13 18:06 config
drwxrwsr-x 5 samsepi01 root 4096 Mar 13 18:06 database
drwxrwsr-x 3 samsepi01 root 4096 Mar 13 18:06 docker
-rw-rw-r-- 1 samsepi01 root 708 Mar 13 18:06 docker-compose.yml
-rw-rw-r-- 1 samsepi01 root 1214 Mar 13 18:06 Dockerfile
-rw-rw-r-- 1 samsepi01 root 213 Mar 13 18:06 .editorconfig
-rw-rw-r-- 1 samsepi01 root 726 Mar 13 18:21 .env
-rw-rw-r-- 1 samsepi01 root 726 Mar 13 18:06 .env.example
drwxrwsr-x 8 samsepi01 root 4096 Mar 13 18:06 .git
-rw-rw-r-- 1 samsepi01 root 111 Mar 13 18:06 .gitattributes
-rw-rw-r-- 1 samsepi01 root 188 Mar 13 18:06 .gitignore
-rw-rw-r-- 1 samsepi01 root 2770 Mar 13 18:14 output.log
-rw-rw-r-- 1 samsepi01 root 1196 Mar 13 18:06 package.json
-rw-rw-r-- 1 samsepi01 root 1156 Mar 13 18:06 phpunit.xml
drwxrwsr-x 5 samsepi01 root 4096 Mar 13 18:06 public
-rw-rw-r-- 1 samsepi01 root 1294 Mar 13 18:06 README.md
drwxrwsr-x 6 samsepi01 root 4096 Mar 13 18:06 resources
drwxrwsr-x 2 samsepi01 root 4096 Mar 13 18:06 routes
-rw-rw-r-- 1 samsepi01 root 563 Mar 13 18:06 server.php
drwxrwsr-x 5 samsepi01 root 4096 Mar 13 18:06 storage
-rw-rw-r-- 1 samsepi01 root 174 Mar 13 18:06 .styleci.yml
-rw-rw-r-- 1 samsepi01 root 276 Mar 13 18:06 tailwind.config.js
drwxrwsr-x 4 samsepi01 root 4096 Mar 13 18:06 tests
-rw-rw-r-- 1 samsepi01 root 9 Mar 13 18:06 test.txt
drwxrwsr-x 42 samsepi01 root 4096 Mar 13 18:17 vendor
-rw-rw-r-- 1 samsepi01 root 703 Mar 13 18:06 webpack.mix.js
-rw-rw-r-- 1 samsepi01 root 298278 Mar 13 18:06 yarn.lock
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ php artisan key:generate
Application key set successfully.
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$
```

To copy the `.env.example` file to `.env`, use :

```
cp .env.example .env
```

Note : Make sure to add the mysql password to the `.env` file.

```
GNU nano 2.9.3                               .env                               Modified

APP_NAME=Laravel
APP_ENV=local
APP_KEY=base64:AKx0ddPMjmamYBz9K57C3rry6sHPa4Zz/X/yA3mbFec=
APP_DEBUG=true
APP_URL=http://localhost

LOG_CHANNEL=stack

DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=laravel
DB_USERNAME=root
DB_PASSWORD=abc123

BROADCAST_DRIVER=log
CACHE_DRIVER=file
QUEUE_CONNECTION=sync
SESSION_DRIVER=file
SESSION_LIFETIME=120

REDIS_HOST=127.0.0.1
REDIS_PASSWORD=null
REDIS_PORT=6379

MAIL_DRIVER=smtp
MAIL_HOST=smtp.mailtrap.io
MAIL_PORT=2525
MAIL_USERNAME=null
MAIL_PASSWORD=null
MAIL_ENCRYPTION=null

^G Get Help   ^O Write Out  ^W Where Is   ^K Cut Text   ^J Justify    ^C Cur Pos    M-U Undo
^X Exit       ^R Read File  ^\ Replace    ^U Uncut Text ^T To Spell   ^_ Go To Line  M-E Redo
```

```
MAIL_PORT=2525
MAIL_USERNAME=null
MAIL_PASSWORD=null
MAIL_ENCRYPTION=null

samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ sudo mysql
[sudo] password for samsepi01:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 4
Server version: 5.7.42-0ubuntu0.18.04.1 (Ubuntu)

Copyright (c) 2000, 2023, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> CREATE DATABASE VULN_DB;
Query OK, 1 row affected (0.01 sec)

mysql> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| VULN_DB          |
| mysql            |
| performance_schema |
| sys              |
+-----+
5 rows in set (0.01 sec)

mysql>
```

```
cd into config and write the following command :  
    chmod -R gu+w storage/  
cd into vulnerable-laravel-app then :  
    chmod -R gu+w storage/  
then clear the cache :  
    php artisan cache:clear
```

```
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app/config$ chmod -R gu+w storage/  
chmod: cannot access 'storage/': No such file or directory  
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app/config$ cd ..  
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ chmod -R gu+w storage/  
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ php artisan cache:clear  
Application cache cleared!  
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$
```

```
sudo chown -R www-data:www-data storage  
sudo chmod -R 775 storage bootstrap/cache
```

To fix any permission issues.

www-data is the user that the web server (Nginx or Apache) runs as. If the web server doesn't "own" these files, it can't write logs or upload files. This ensures that both the web server and your terminal user (if they are in the www-data group) can modify the cache and logs, while preventing random guests on the system from changing them.

```
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ sudo chown -R www-data:www-data storage bootstrap/cache
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$ sudo chmod -R 775 storage bootstrap/cache
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app$
```

Next, we fix the 000-default.conf file

```
sudo nano /etc/apache2/sites-enabled/000-
default.conf
```

DocumentRoot

```
/var/www/html/vulnerable-laravel-app/public
```

```

GNU nano 2.9.3                                000-default.conf
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    #ServerName www.example.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html/vulnerable-laravel-app/public

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
    # include a line for only one particular virtual host. For example the
    # following line enables the CGI configuration for this host only
    # after it has been globally disabled with "a2disconf".
    #Include conf-available/serve-cgi-bin.conf
</VirtualHost>

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet

samsepi01@ubuntu_server:/etc/apache2/sites-enabled$ cle_

```

Then,

```

<Directory
"/var/www/html/vulnerable-laravel-app/public>
    AllowOverride All
</Directory>

```

```

GNU nano 2.9.3 /etc/apache2/sites-enabled/000-default.conf
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    #ServerName www.example.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html/vulnerable-laravel-app/public

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn
    <Directory "/var/www/html/vulnerable-laravel-app/public">
        AllowOverride All
    </Directory>

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
    # include a line for only one particular virtual host. For example the
    # following line enables the CGI configuration for this host only
    # after it has been globally disabled with "a2disconf".

```

samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app\$ cl

Then cd back into vulnerable-laravel-app and open the .htaccess file.

Then add this :

```

RewriteBase /
RewriteCond %{REQUEST_FILENAME} !-f
RewriteCond %{REQUEST_FILENAME} !-d
RewriteRule ^(.*)$ index.php/$1 [L]

```

Comment out the rest of the RewriteCond and Rewrite Rule lines.

```
GNU nano 2.9.3 .htaccess Modified
<IfModule mod_rewrite.c>
  <IfModule mod_negotiation.c>
    Options -MultiViews -Indexes
  </IfModule>

  RewriteEngine On
  #Options +FollowSymLinks

RewriteBase /
RewriteCond %{REQUEST_FILENAME} !-f
RewriteCond %{REQUEST_FILENAME} !-d
RewriteRule ^(.*)$ index.php/$1 [L]

  # Handle Authorization Header
  # RewriteCond %{HTTP:Authorization} .
  # RewriteRule .* - [E=HTTP_AUTHORIZATION:%{HTTP:Authorization}]

  # Redirect Trailing Slashes If Not A Folder...
  #RewriteCond %{REQUEST_FILENAME} !-d
  #RewriteCond %{REQUEST_URI} (.+)/$
  #RewriteRule ^ %1 [L,R=301]

  # Handle Front Controller...
  #RewriteCond %{REQUEST_FILENAME} !-d
  #RewriteCond %{REQUEST_FILENAME} !-f
  #RewriteRule ^$ index.php [L]
</IfModule>

^G Get Help  ^O Write Out ^W Where Is  ^K Cut Text  ^J Justify   ^C Cur Pos  M-U Undo
^X Exit      ^R Read File ^_ Replace   ^U Uncut Text ^T To Spell  ^_ Go To Line M-E Redo
```

then restart apache2
sudo systemctl restart apache2

```
#Options +FollowSymLinks

RewriteBase /
RewriteCond %{REQUEST_FILENAME} !-f
RewriteCond %{REQUEST_FILENAME} !-d
RewriteRule ^(.*)$ index.php/$1 [L]

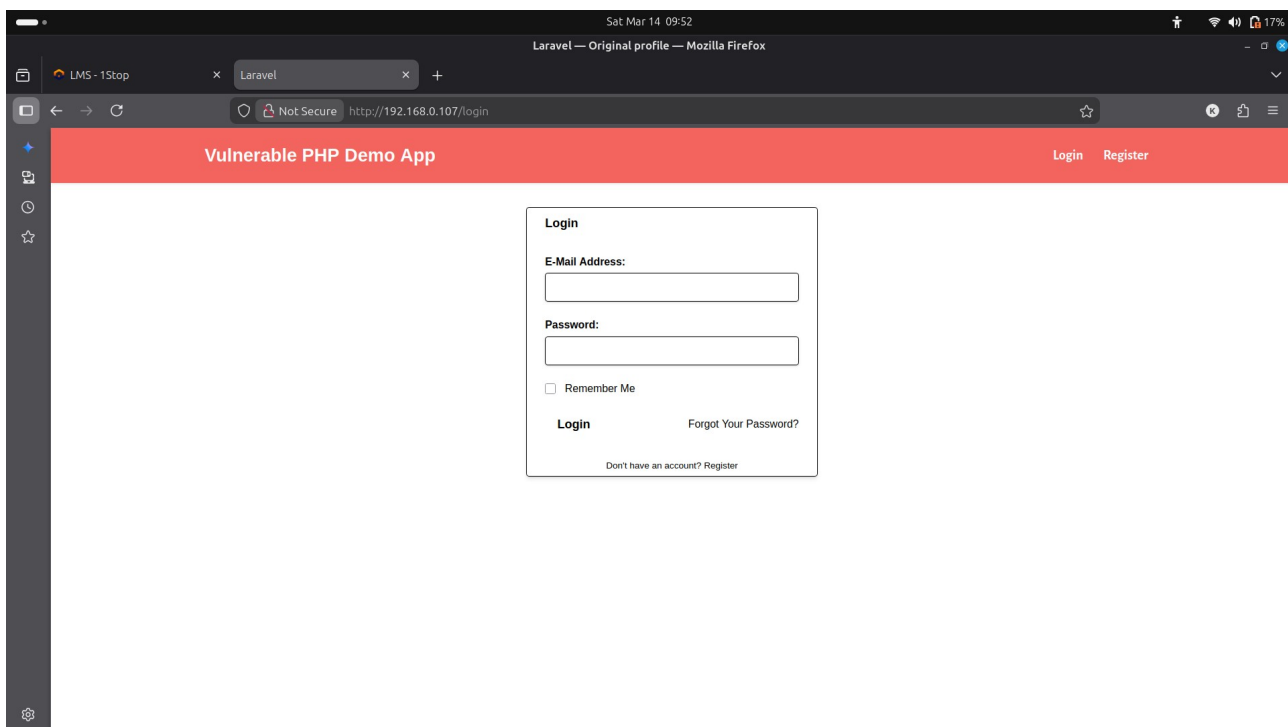
# Handle Authorization Header
# RewriteCond %{HTTP:Authorization} .
# RewriteRule .* - [E=HTTP_AUTHORIZATION:%{HTTP:Authorization}]

# Redirect Trailing Slashes If Not A Folder...
#RewriteCond %{REQUEST_FILENAME} !-d
#RewriteCond %{REQUEST_URI} (.+)/$
#RewriteRule ^ %1 [L,R=301]

# Handle Front Controller...
#RewriteCond %{REQUEST_FILENAME} !-d
#RewriteCond %{REQUEST_FILENAME} !-f
#RewriteRule ^$ index.php [L]
</IfModule>

samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app/public$ sudo systemctl restart apach2
Failed to restart apach2.service: Unit apach2.service not found.
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app/public$ sudo systemctl restart apache2
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app/public$ sudo a2enmod rewrite
Enabling module rewrite.
To activate the new configuration, you need to run:
systemctl restart apache2
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app/public$ sudo systemctl restart apache2
samsepi01@ubuntu_server:/var/www/html/vulnerable-laravel-app/public$ _
```

The login page looks like this.



Our vulnerable web server setup is done.

Vulnerability Assessment

Initial Tests :

Telnet connection :

```
Terminal - samsepi0l@ubuntu_server: ~
Sat Mar 14 09:53

File Edit View Terminal Tabs Help
samsepi0l@fsociety:~$ telnet 192.168.0.107
Trying 192.168.0.107...
Connected to 192.168.0.107.
Escape character is '^]'.
Ubuntu 18.04.6 LTS
ubuntu_server login: samsepi0l
Password:
Last login: Sat Mar 14 03:03:50 UTC 2026 on tty1
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 4.15.0-213-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat Mar 14 03:31:03 UTC 2026

System load:  0.0               Processes:    101
Usage of /:   51.1% of 7.77GB   Users logged in: 1
Memory usage: 67%              IP address for enp0s3: 192.168.0.107
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

159 updates can be applied immediately.
125 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

samsepi0l@ubuntu_server:~$
```

SSH Connection :

```
Terminal - samsepi0l@ubuntu_server: ~
Sat Mar 14 09:56

File Edit View Terminal Tabs Help
samsepi0l@fsociety:~$ ssh samsepi0l@192.168.0.107
samsepi0l@192.168.0.107's password:
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 4.15.0-213-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat Mar 14 03:34:27 UTC 2026

System load:  0.0               Processes:    99
Usage of /:   51.1% of 7.77GB   Users logged in: 1
Memory usage: 67%              IP address for enp0s3: 192.168.0.107
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

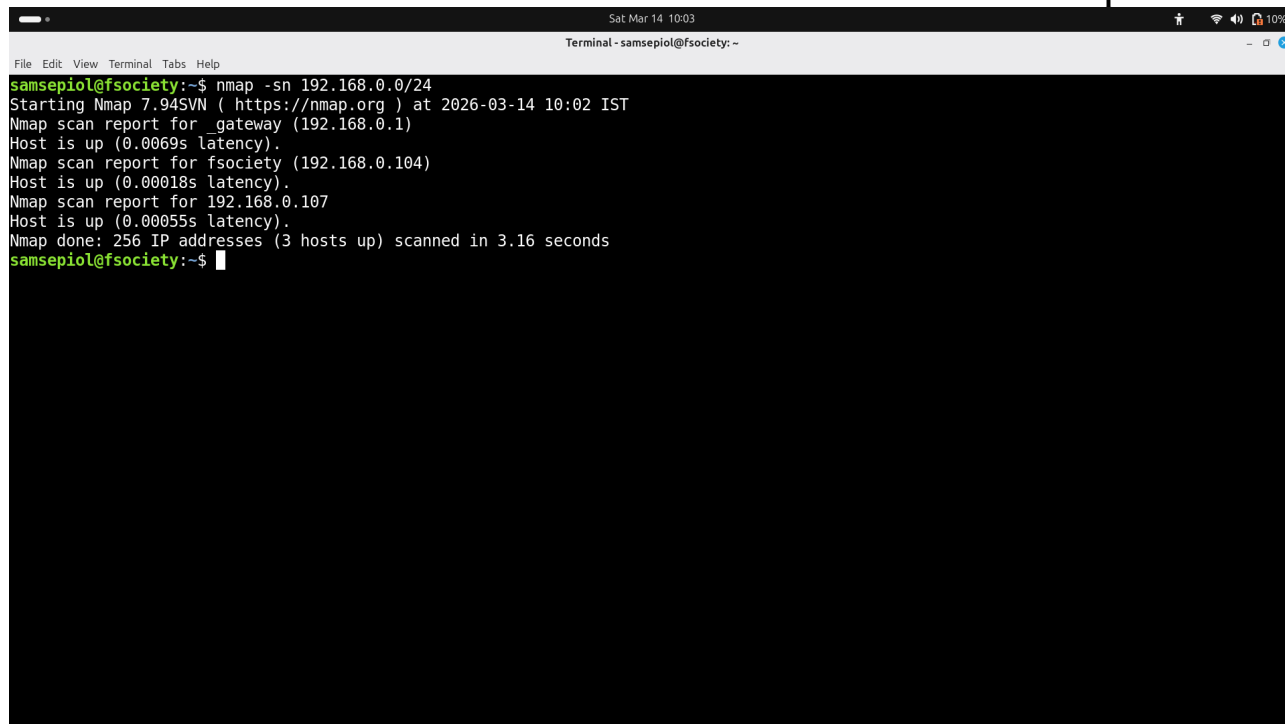
159 updates can be applied immediately.
125 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

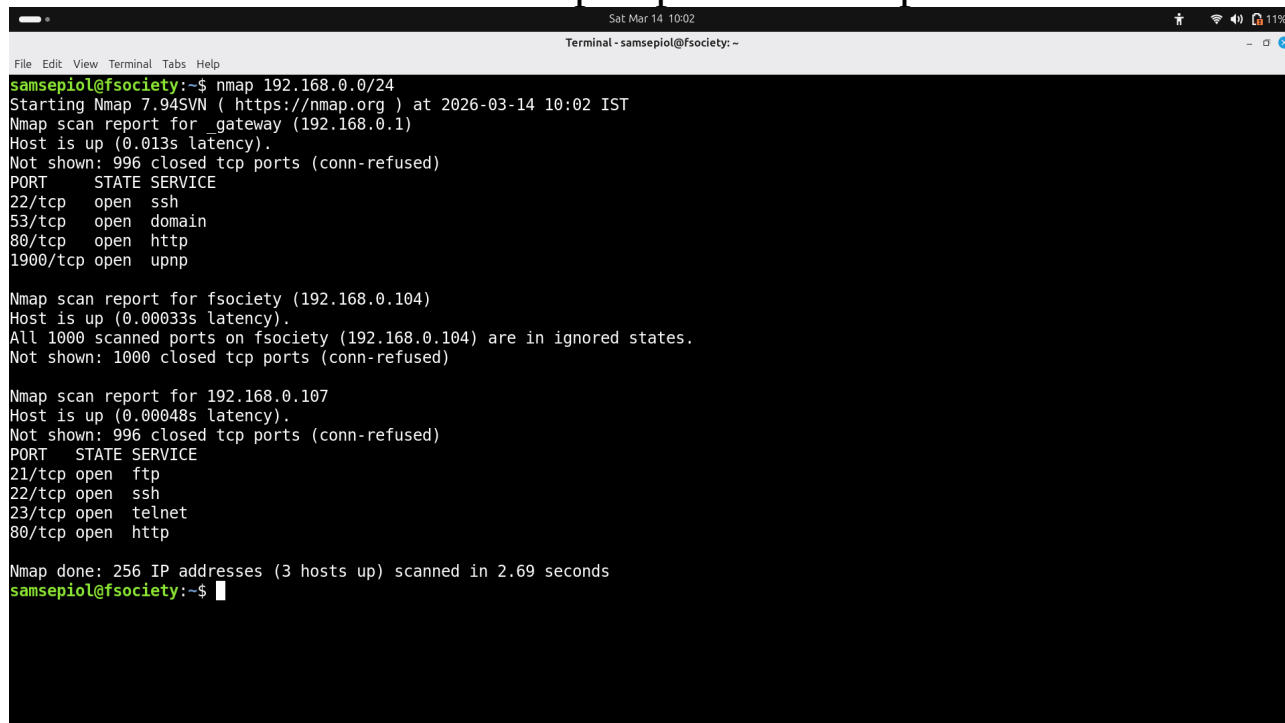
Last login: Sat Mar 14 03:31:03 2026 from 192.168.0.104
samsepi0l@ubuntu_server:~$
```

NMAP subnet scan to check if host is discoverable and up :

A terminal window titled "Terminal - samsepiol@fsociety: ~" showing an Nmap command and its output. The command is "nmap -sn 192.168.0.0/24". The output shows three hosts are up: gateway (192.168.0.1), fsociety (192.168.0.104), and 192.168.0.107. The scan took 3.16 seconds.

```
Samsepiol@fsociety:~$ nmap -sn 192.168.0.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 10:02 IST
Nmap scan report for gateway (192.168.0.1)
Host is up (0.0069s latency).
Nmap scan report for fsociety (192.168.0.104)
Host is up (0.00018s latency).
Nmap scan report for 192.168.0.107
Host is up (0.00055s latency).
Nmap done: 256 IP addresses (3 hosts up) scanned in 3.16 seconds
samsepiol@fsociety:~$
```

NMAP scan to discover the open ports of the ip address in subnet :

A terminal window titled "Terminal - samsepiol@fsociety: ~" showing an Nmap command and its output. The command is "nmap 192.168.0.0/24". The output shows three hosts are up: gateway (192.168.0.1), fsociety (192.168.0.104), and 192.168.0.107. For each host, it lists open ports and services. The scan took 2.69 seconds.

```
Samsepiol@fsociety:~$ nmap 192.168.0.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 10:02 IST
Nmap scan report for gateway (192.168.0.1)
Host is up (0.013s latency).
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
1900/tcp   open  upnp

Nmap scan report for fsociety (192.168.0.104)
Host is up (0.00033s latency).
All 1000 scanned ports on fsociety (192.168.0.104) are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 192.168.0.107
Host is up (0.00048s latency).
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
80/tcp    open  http

Nmap done: 256 IP addresses (3 hosts up) scanned in 2.69 seconds
samsepiol@fsociety:~$
```

Aggressive NMAP scan on the server to check which services are installed :

```
Sat Mar 14 10:01
Terminal - samsepiol@fsociety: ~

File Edit View Terminal Tabs Help

samsepiol@fsociety:~$ nmap -A -T4 192.168.0.107
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 10:00 IST
Nmap scan report for 192.168.0.107
Host is up (0.00041s latency).
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 09:ba:76:fb:a9:d3:87:9d:68:2c:c3:95:2a:d2:8d:25 (RSA)
|   256  a5:80:ad:39:82:5b:2f:0d:b4:62:69:be:df:2a:13:16 (ECDSA)
|_  256  1d:69:ee:6f:44:2f:7f:f2:fe:d8:9e:9f:30:9c:22:07 (ED25519)
23/tcp    open  telnet   Linux telnetd
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Laravel
|_ http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.04 seconds
samsepiol@fsociety:~$
```

NMAP vuln script execution to check for XSS or CSRF vulnerabilities:

```
Sat Mar 14 10:10
Terminal - samsepiol@fsociety: ~

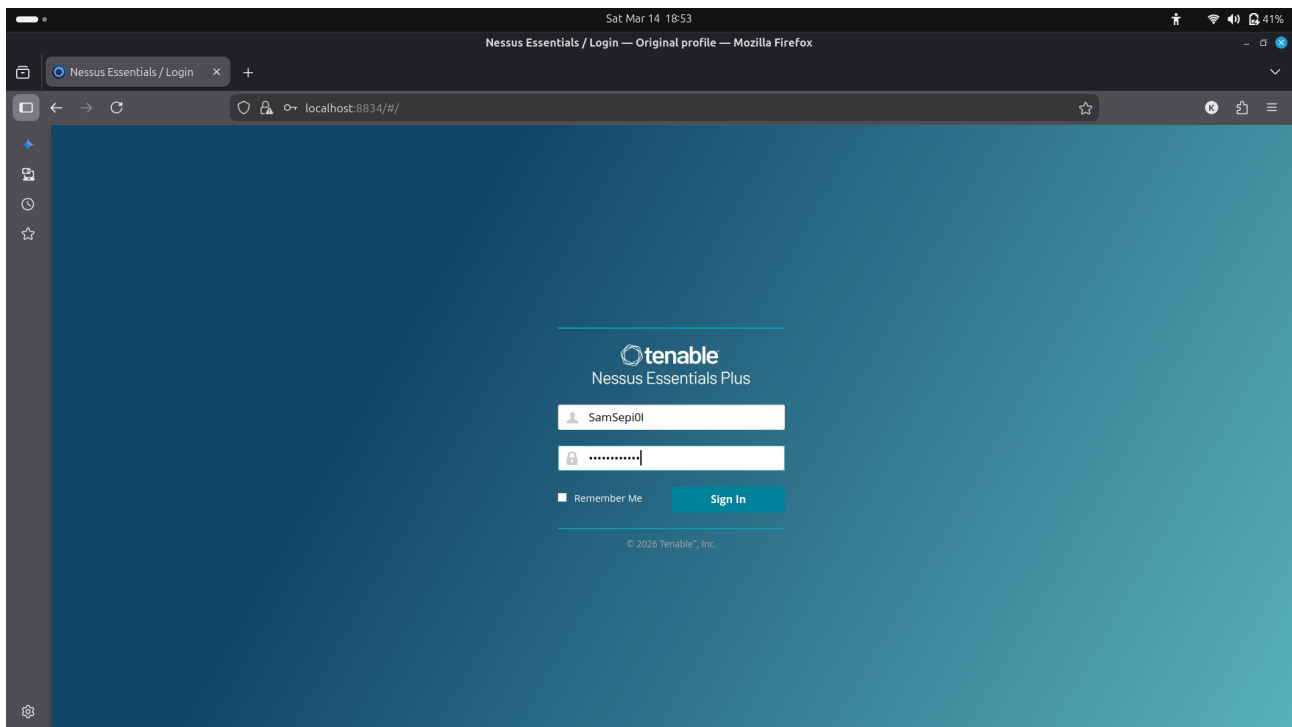
File Edit View Terminal Tabs Help

samsepiol@fsociety:~$ sudo nmap -Pn --script vuln 192.168.0.107
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 10:07 IST
Nmap scan report for 192.168.0.107
Host is up (0.0017s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
80/tcp    open  http
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-enum:
|   /login/: Login page
|   /test.php: Test page
|   /robots.txt: Robots file
|   /register/: Potentially interesting folder
MAC Address: 08:00:27:B1:32:E7 (Oracle VirtualBox virtual NIC)

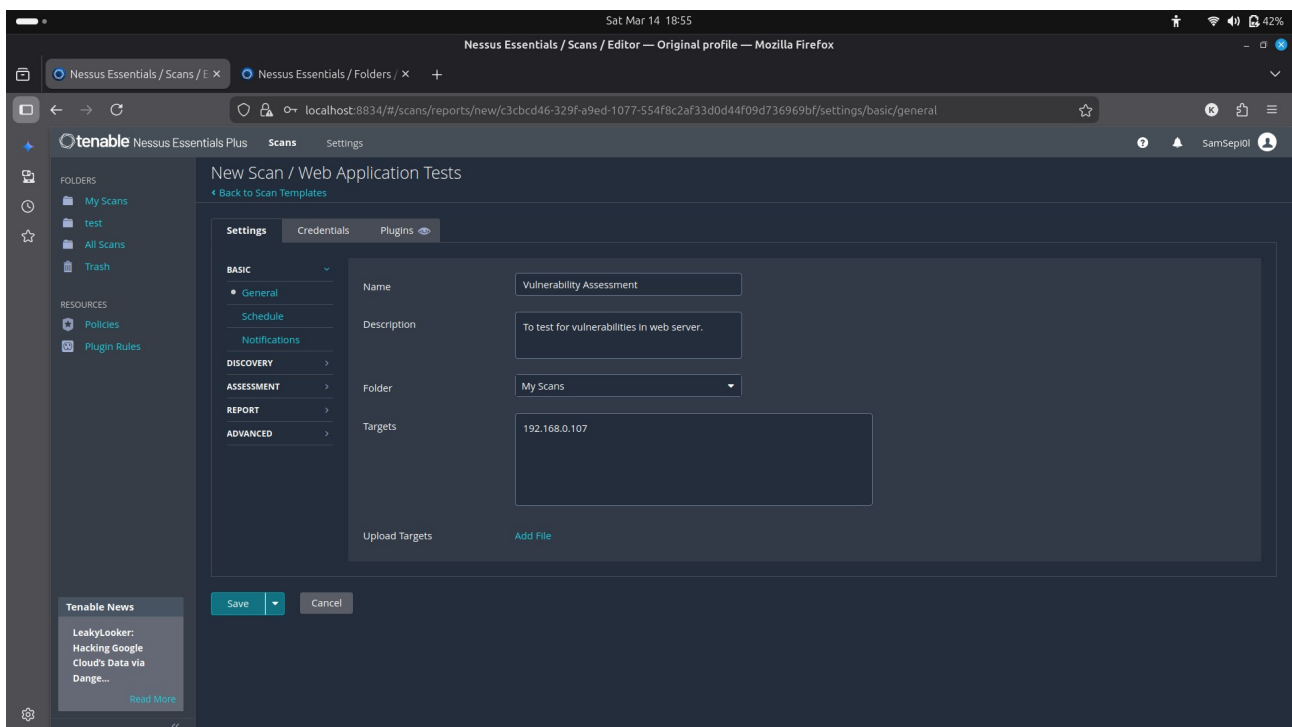
Nmap done: 1 IP address (1 host up) scanned in 100.52 seconds
samsepiol@fsociety:~$
```

Nessus Web Application Scanning and Report Generation

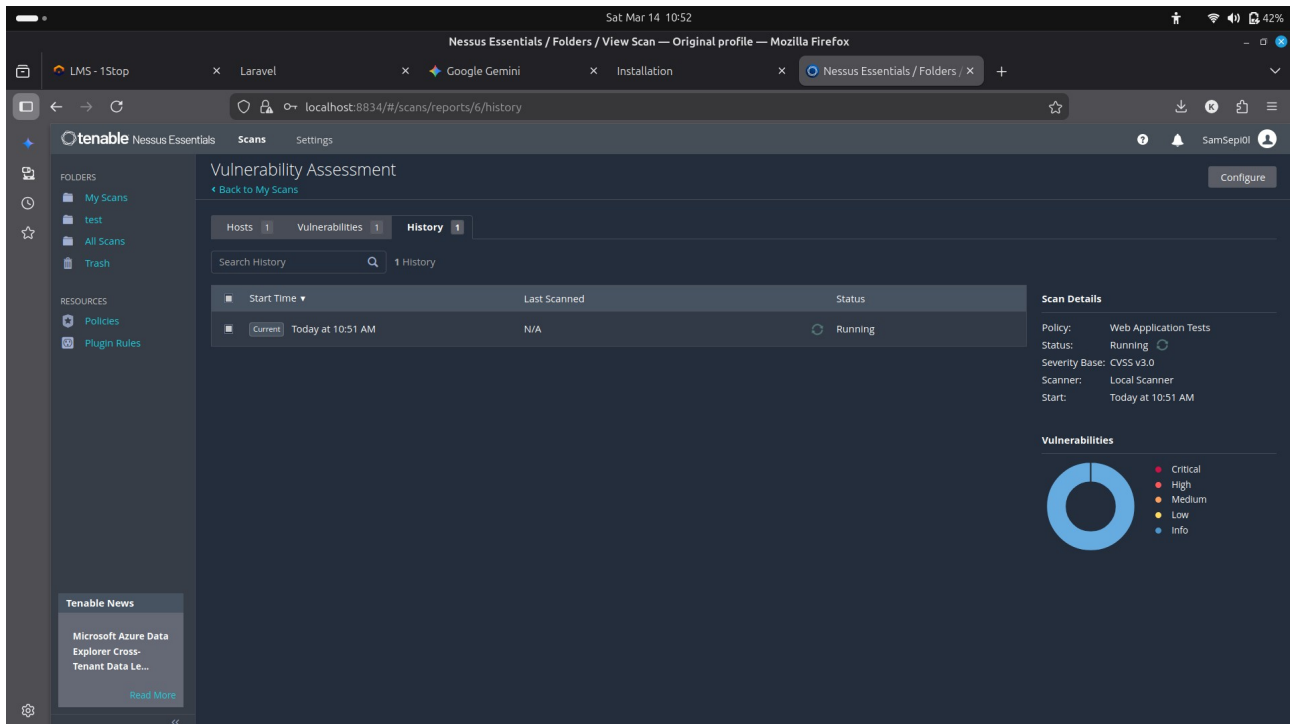
Nessus Login Page :



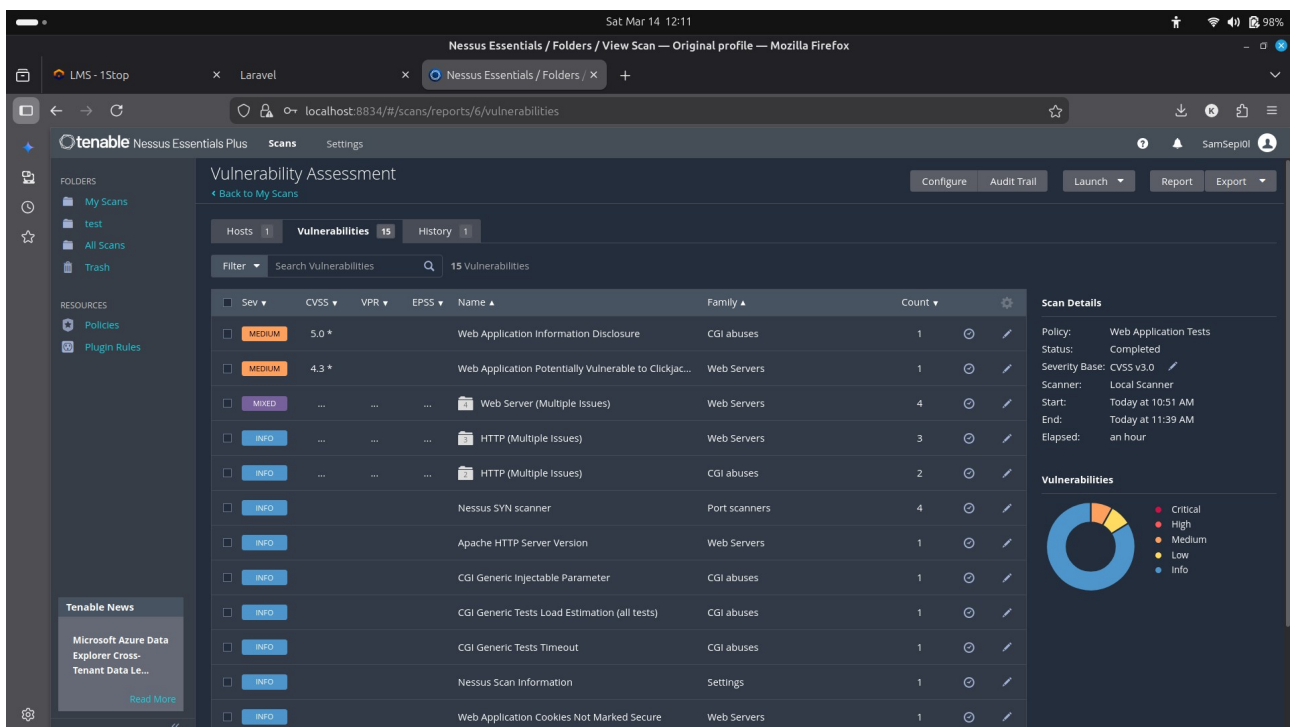
Create a New Scan for Web Application Tests:



Start the Vulnerability Scan :



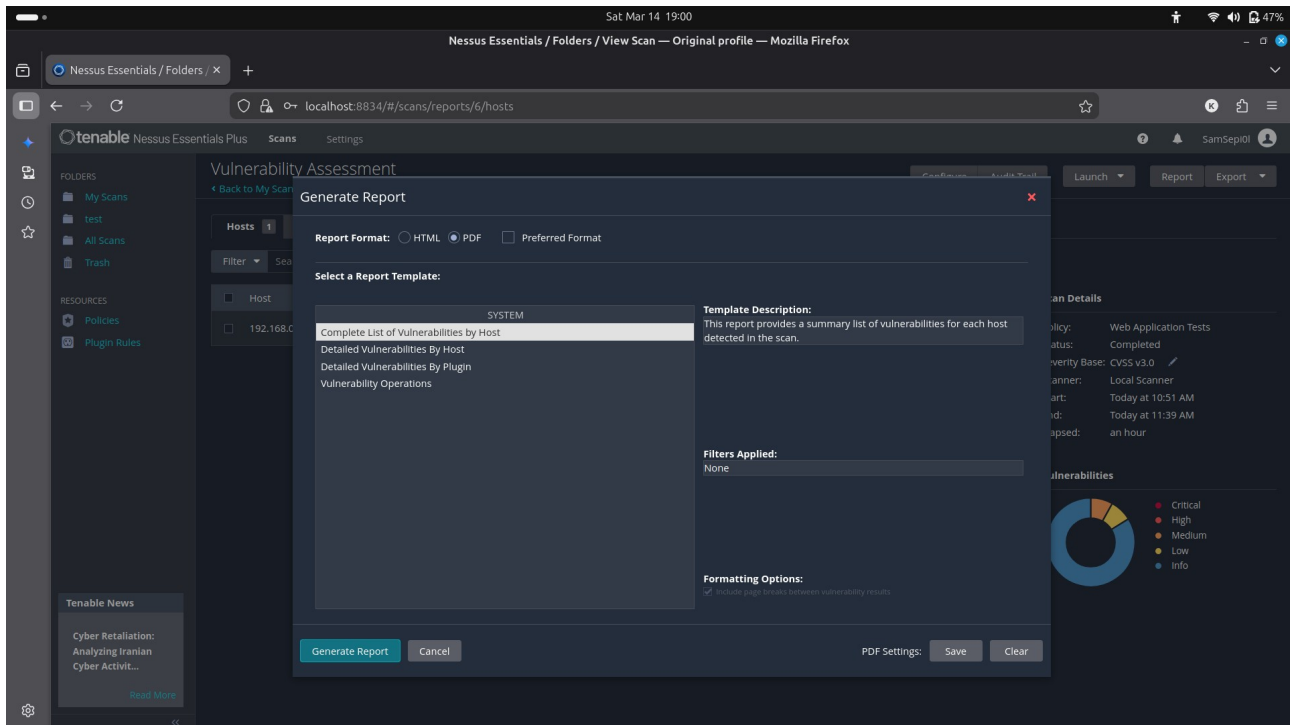
After Completion :



To save the Report as PDF :

1. Go to Report
2. Select Report Format as PDF
3. Select Detailed Vulnerabilities by Host

4. Select Generate Report



Conclusion

The vulnerability assessment of the target host indicates a Medium-risk security posture. While no critical or high-severity exploits were found, the server is susceptible to several well-known web configuration weaknesses. The primary risks identified involve information disclosure and client-side manipulation, which could be leveraged to facilitate more advanced social engineering or data interception attacks.

Analysis of Key Risks

- **Web Application Vulnerabilities (Medium):** The most significant findings (Plugin #57640 and #85582) suggest the server is leaking technical details and lacks protection against Clickjacking. An attacker could use this information to map the application's backend or trick users into performing unintended actions.

- **Credential Security (Low):** The findings regarding Cleartext Credentials (Plugin #26194) and Password Auto-Completion (Plugin #42057) are particularly concerning for user privacy. Transmitting data over unencrypted channels allows for easy interception via "Man-in-the-Middle" (MitM) attacks.
- **Reconnaissance Surface (Info):** With 17 informational findings, the server is "chatty." Notable issues include the disclosure of the Apache version, robots.txt contents, and directory enumeration. These provide a roadmap for an attacker to identify specific version-based exploits.